



以运行时证据为核心， 能够验证修复结果的 AI 调试工具

0.1.0 开发版

上海开源软件应用创新大赛项目介绍

把 Trace、日志、源码、Git、模型结论、Patch 与回归结果封装为一个可移植、可校验、默认脱敏的故障胶囊。模型提出建议，确定性代码约束证据与边界，人类批准后才进入隔离验证。



Trace → Code → Patch → Test

每个结论可回溯，每个文件有 SHA-256，每个 Patch 受路径与证据约束，每次验证保留修复前后事实。

调试的真正缺口：结论无法形成可验证链路

现有工具能看到指标、日志或模型回答，但事故复盘常停在“可能是这里”。BugCapsule 把分散信息转成一个有边界、有引用、有批准、有回归的工程对象。

01

证据分散

Trace、日志、Stack Trace、源码和 Git 版本分属不同工具，复现时上下文已经丢失。

02

结论难追溯

模型可以给出流畅解释，但未知 Evidence ID、漏引证据和原始响应很难被程序拒绝。

03

修复难信任

生成 Diff 不等于修复成立；路径越界、确认后替换和只测修复后都会制造假阳性。

BugCapsule 的回答

事实源

.bugcapsule 保存完整性清单与证据载荷

引用约束

根因与 Patch 只能引用本次输入中的 Evidence ID

人工边界

Patch ID + SHA-256 + 明确批准三重绑定

验证事实

before 失败、after 通过，输出再次脱敏并归档

设计原则

证据优先

状态以文字与形态表达

离线可演示

模型不直接修改主仓库

一个胶囊贯穿捕获、分析、确认与验证

SQLite 只保存可重建元数据；所有详情视图都会重新校验胶囊、重建证据链。CLI、Web 和 HTML 报告不各自维护事实副本。



信任边界

胶囊内容视为不可信输入；模型输出视为候选；只有确定性 Schema、Evidence ID、路径与哈希校验后的结构化结果才能写回。验证器不挂载 Docker Socket、密钥或用户目录。

默认拒绝



主演示：数据库连接池耗尽，可复现、可重置

订单服务固定使用两个连接、零 overflow 和短超时。异常路径把 Session 留在请求注册表中；前两次请求占满连接，第三次请求稳定得到 503。



固定工程参数

pool_size	2
max_overflow	0
监听	127.0.0.1
容器	non-root / read-only
重置	demo reset

仿真胶囊 BC-EVAL-001 的证据链

EV-54D6D74FFE11	Trace	POST /orders/leak 状态 ERROR
EV-776F31252B0D	Span	SELECT orders 状态 ERROR
EV-1C53B791D57C	Log	database pool exhausted
EV-1AABEC87CBC0	Source	repository.py:45 Session 未关闭

部分验证

单元测试与本机固定回归已验证状态序列；当前 Windows 开发机未安装 Docker CLI，因此 Compose 主场景和受限容器 20 次回归仍需在 GitHub Actions 或具备 Docker Engine 的环境完成。文档不把 CI 配置冒充实机结果。



模型负责提出候选，确定性代码负责决定能否成立

BugCapsule 不发送整个仓库。模型输入只包含已脱敏、按优先级选择、受字节上限约束的证据；响应必须通过严格 Schema 和 Evidence ID 校验。

模型看到什么

- 1 已脱敏的排序证据，不含整个仓库
- 2 固定系统指令与严格输出 Schema
- 3 provider / model / API style 请求摘要
- 4 胶囊内容被明确标记为不可信数据

模型不能指定 Root Cause ID

本地决定什么

- 结构** 连续排名、字段边界、重复候选
- 引用** 每个 Evidence ID 必须存在于本次请求
- 持久化** 只保存验证后的结构化结果
- 失败** 无效响应只重试一次，随后解释性失败

原始提示与响应不落盘

三种显式模式

live

调用配置的 OpenAI-compatible 提供方

真实模型能力

replay

按完整请求 SHA-256 读取录制结构

离线管线复现

off

不访问模型、不读取回放

纯确定性证据

诚实边界

注释 replay 的 100% 结果只证明完整分析链、引用校验和评分方法可复现；比赛采用的 Live 模型必须单独运行、单独报告，失败案例仍进入分母。

Patch 先被约束，再被批准，最后才被验证

模型只提出 unified diff。Patch ID、Diff SHA-256、修改文件清单、安全结论和验证命令均由本地生成；模型不能覆盖测试、锁文件、CI 或 Docker 配置。

```
verification_tests/fixtures/connection-release.diff

@@ -42,7 +42,7 @@
    session.execute(statement)
- registry.retain(session)
+ session.close()

    return order
```

canonical unified diff

批准前必须同时匹配

- 01 完整 Patch ID
 - 02 完整 64 位 SHA-256
 - 03 显式 approve=true
- 任何不匹配：执行前拒绝

受限验证容器

USER 10001:10001	NETWORK none	ROOT FS read-only
CAPS drop ALL	SECURITY no-new-privileges	LIMITS CPU / memory / PID / timeout

CI 待实机

工作流已配置修复前 20 次预期失败、应用固定 Patch 后 20 次预期通过；本机完成了固定回归逻辑检查，但因 Docker CLI 缺失，不把受限容器 20/20 配置写成已完成实测。



用可复现实测回答准确率、时延、质量与供应链

以下结果均绑定 2026-08-26 仓库快照。Replay 指标来自公开注释，只验证管线；性能为单机测量，不是服务等级承诺。

100%

Top-1 注释匹配率

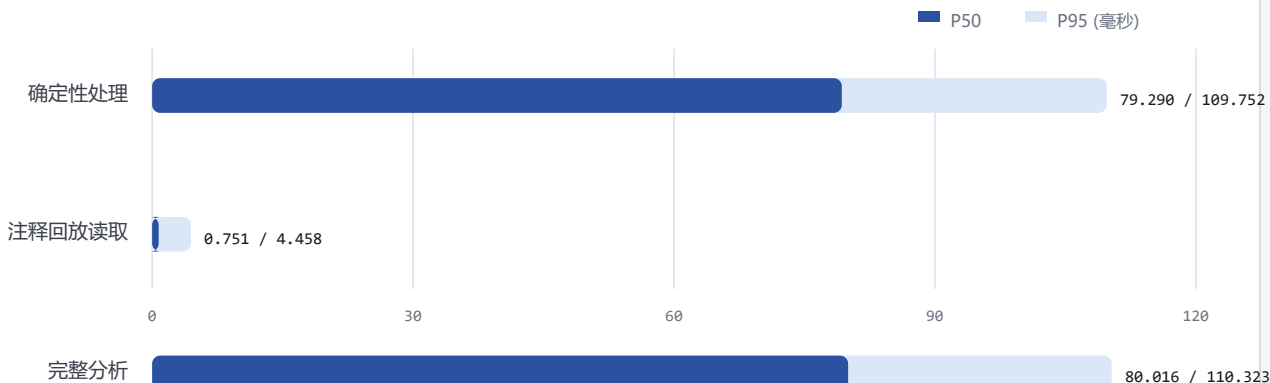
100%

Evidence 引用有效率

100%

必需 Trace / Log / Source 覆盖

12 案例分析时延 P50 / P95



154

全量测试通过

90.76%

分支感知覆盖率

3.10-3.12

Python CI 矩阵

0

已知漏洞 (审计 47 依赖)

供应链快照

CycloneDX 1.6 SBOM: 48 组件 | pip-audit: 47 生产依赖、0 已知漏洞 | wheel + sdist + SHA256SUMS

提交的是可持续验证的开源工程，而不是一次性演示

四项评分维度均有机器可读证据索引；权重合计 100%，每项声明绑定文件、复现命令和诚实状态。外部依赖未完成时保持开发版，不创建正式标签。

30%

技术创新

开放 Schema / Evidence ID
/ Patch 安全

30%

场景落地

真实连接池故障 / CLI / Web
/ Report

20%

开源治理

Apache-2.0 / SBOM /
Threat Model

20%

长期发展

适配接口 / 路线图 / 外部试用

已完成的开源基线

- Apache License 2.0 / NOTICE / Third Party
- 中英文 README / Issue / PR / Security
- 威胁模型与默认脱敏边界
- CycloneDX SBOM 与依赖审计
- 示例胶囊与量化基准
- Gitee master 按功能提交

正式 v0.1.0 前必须清零

外部待完成

- 01 Docker Compose 主场景与受限 20/20 实机
- 02 比赛默认 Live 模型独立指标
- 03 3-5 名首次使用者匿名汇总
- 04 3-5 分钟视频与三分钟断网彩排
- 05 GitHub 镜像同步与双远端同一 Release

评审入口

主仓库 <https://gitee.com/lan0811/bug-capsule>

证据索引 [docs/submission-evidence.md](#) | [examples/README.md](#) | [docs/supply-chain.md](#)